

Dispute Chamber

Decision 170/2023 of December 20, 2023

File Number: DOS-2019-04346

Subject: Data Leak in the Context of a Loyalty Program

The Dispute Chamber of the Data Protection Authority, consisting of the Chair Mr. Hielke HIJMANS and the members Mr. Dirk Van Der Kelen and Mr. Christophe Boeraeve;

Based on Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data, on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation), hereinafter referred to as GDPR;

Based on the Act of December 3, 2017, establishing the Data Protection Authority (hereinafter DPA);

Based on the Rules of Procedure, as approved by the House of Representatives on December 20, 2018, and published in the Belgian Official Gazette on January 15, 2019;

Based on the case file;

made the following decision regarding:

The Defendant:

Y, represented by Attorney Cédric Burton and Attorney Laura Brodahl, hereinafter referred to as "the Defendant."

Decision in Case 170/2023 — 2/9

I. Facts and Procedure

A. Investigation of the Inspection Service

1.

On December 20, 2019, the Board of the Data Protection Authority (hereinafter "DPA") decided to involve the Inspection Service of the DPA in a case based on Article 63, 1° of the LCA, as there were apparently serious indications that the Defendant had failed to comply with its obligations under Article 32 of the GDPR. The factors considered by the Board in this context were the extent of the data leak (the number of affected individuals amounted to 89,429 in 27 EU Member States) and the nature of the disclosed data, namely card number, name of the affected person, date of birth, gender, address, email address, telephone number, mobile phone number, and a unique identification number.

2. After the Secretariat of the Data Protection Authority processed the data leak that occurred at the Defendant on August 19, 2019, and handled the complaints submitted by individuals in Germany as affected persons to the First-Line Service of the Data Protection Authority, the case was reviewed by the Board and forwarded to the Inspection Service in accordance with Article 63, paragraph 1 of the LCA. The individual complaints from German citizens were also forwarded to the Inspection Service after being declared admissible by the First-Line Service, in accordance with Article 96, paragraph 1 of the LCA in conjunction with Article 63, paragraph 2 of the LCA.

3. The reason for the aforementioned involvement was a specific data leak at a subcontractor of the Defendant. This subcontractor operates the platform (..) program, where cardholders can register for a loyalty program based on points they earn when making purchases with their card. Through this platform, cardholders could access their data, including their points balance, and then use it for promotions from participating merchants who displayed their offers on the platform. The subcontractor, in turn, commissioned another subcontractor for external hosting/external logging.

4. On July 20, 2023, the investigation of the Inspection Service was completed, the report was attached to the file, and this was forwarded by the General Inspector to the Chair of the Dispute Chamber (Art. 91, paragraph 1 and paragraph 2 of the LCA), which led to the involvement of the Dispute Chamber in accordance with Art. 92, paragraph 3 of the GSD. In its report, the Inspection Service concluded that the large number of individuals affected by the data leak and compliance with the reporting obligation to the DPA were not sufficient, on their own, to indicate a practice that would lead to a violation of the fundamental principles of personal data protection.

Decision in Case 170/2023 — 3/9

Data in the sense of Article 63, paragraph 1 of the LCA could lead to. Otherwise, the inspection report contains no findings of a violation of the GDPR by the defendant.

B. Proceedings before the Dispute Chamber

5. On September 27, 2023, the Dispute Chamber decides in accordance with Article 95, paragraph 1, item 1 and Article 98 of the LCA that the case can be processed. The defendant is informed by registered mail about the provisions as outlined in Article 95, paragraph 2 as well as Article 98 of the LCA. They are also informed about the deadline for submitting the conclusion in accordance with Article 99 of the LCA. The deadline for the defendant's response to the complaint was originally set for October 30, 2023, but was extended to November 15, 2023.

6. On October 6, 2023, the defendant requested a copy of the file (Art. 95, paragraph 2, item 3 of the LCA), which was transmitted to them on October 18, 2023, and completed on October 25, 2023. The defendant also agrees to receive all communications regarding the case electronically, as provided for in Article 98 DSG.

7. On November 10, 2023, the parties are informed that the hearing will take place on December 1, 2023.

8. On November 15, 2023, the Dispute Chamber receives the defendant's response. In addition to the defense on the merits, which mainly refers to the technical report of the inspection service, these conclusions also address some procedural defenses related to how the inspection service was engaged and conducted the investigation.

9. On December 1, 2023, the defendant is heard by the Dispute Chamber. The defendant is therefore heard and given the opportunity to present their arguments. The case is then deliberated by the Dispute Chamber.

10. On December 8, 2023, the minutes of the hearing are presented to the defendant in accordance with Article 54 of the Rules of Procedure. The defendant is thus given the opportunity to add any comments they may have regarding the minutes in an annex, without this constituting a reopening of the proceedings.

11. On December 15, 2023, the Dispute Chamber receives some comments on the minutes, which it intends to include in its deliberation.

Decision in Case 170/2023 — 4/9

II. Justification

A. Procedure

12. The defendant argues that an investigation by the board or the inspection service can only be initiated on its own initiative if there are serious indications of non-compliance. According to the defendant, neither of the two bodies has established the existence of such indications. Both would therefore have unlawfully conducted an investigation regarding the processing activities of the defendant.

13. In this context, the Dispute Chamber must point out that in the note sent by the Secretariat to the board following the report of the data breach by the defendant, which served as the basis for the board's decision to refer the case to the inspection service, it is clearly mentioned that sufficient elements in the note indicate a practice that leads to a violation of the fundamental principles of personal data protection (Article 63, paragraph 1 of the LCA). The relevant note explicitly refers to the large number of individuals affected by this data breach in 27 EU member states. The note also points out that the DSB has already received seven complaints from German citizens and that the supervisory authority of the German federal state of Hesse itself has received about three hundred complaints regarding this data breach, which could still be forwarded to the DSB.

14. The Dispute Chamber finds that there were indeed serious indications based on the note that could point to a practice leading to data protection violations. In this context, it was necessary to consider not

only the impact of the data breach on the large number of affected individuals but also the nature of the data, which potentially consisted of financial data. In the view of the Dispute Chamber, these indications at least provided sufficient justification for examining whether the statement made by the defendant in the note, that the payment network is separate from the platform on which the personal data of customers is collected under the (...) program, is accurate.

15. Obviously, it can only be determined after an investigation by the inspection service whether there is, if applicable, no practice in the sense of Article 63, paragraph 1 of the LCA. This finding of the inspection service does not affect the legality of the board's decision that, based on the elements available at that time and thus before the investigation by the inspection service, there were serious indications that warranted an investigation by the inspection service. The Dispute Chamber therefore believes that the inspection service in

Decision in Case 170/2023 — 5/9

was addressed in accordance with Article 63, paragraph 1 of the LCA and conducted its investigation properly.

16. The defendant further argues that the DSB did not formulate any claim of non-compliance. The defendant refers to the inspection report, in which no violations were found, as well as to the letter from the dispute chamber, in which the defendant is requested to comment on the measures it has taken in accordance with Articles 24 et seq. of the GDPR.

17. The dispute chamber states that there was demonstrably a data breach in 2019, but it wishes to consider the interim developments in its decision in order to obtain a comprehensive picture of the current situation and thus arrive at a balanced statement. Only in this context did the dispute chamber examine the case substantively and requested the defendant to explain the technical and organizational measures taken.

B. Technical and Organizational Measures

18. According to the information submitted by it, the defendant immediately blocked the program's website (..) as soon as it became aware of the data breach and removed all access to the data stored on the platform. The defendant assessed the impact of the incident and concluded that it posed no increased risk to individuals. The incident was limited to the program and did not affect the defendant's payment network in any way. Nevertheless, the defendant, out of excessive caution, also informed the affected individuals on August 22, 2019, so that they could take any necessary precautions if needed.

19. Regarding the data breach that led to this decision, the dispute chamber must therefore establish that the defendant reported this data breach to the DSB within the framework prescribed by Article 33 of the GDPR, even though the data breach was assessed by the defendant as low risk for the affected individuals. Specifically, regarding the reporting of the data breach to the DSB, the defendant acted in accordance with the GDPR.

20. Furthermore, the facts in the file show that there were no repeated data breaches indicating a systematic failure by the defendant, as a result of which it would not have complied with its obligations under Article 24 in conjunction with Article 32 of the GDPR. The data breach represents a completely isolated circumstance.

21. In addition, the documents submitted by the defendant to the file allowed the dispute chamber to gain a profound understanding of the defendant's proactive approach to preventing a recurrence of events as they occurred. These measures were evaluated by the dispute chamber, which reached the following conclusions.

22. The defendant continues to successfully develop its procedures with respect to providers. These developments include a range of initiatives that go beyond the legal requirements. In connection with its obligation to ensure continuous security, the defendant reviews and improves its data security measures, taking into account technological advancements available in the market and following the "state of the art," which is constantly evolving. In particular, the defendant acted as follows:

- It updated its due diligence questionnaires for providers as well as its policies and processes for risk assessment of providers;
- It conducted audits of active providers in Europe;
- It reviewed the certifications of providers operating in Europe;

- It conducted training for employees from various departments on roles and responsibilities in provider risk management;
- It immediately integrated the provider management program into the other processes of the company;
- It added a new risk level to its risk assessment model;
- It updated its tracking tools to make control and tracking of providers more efficient and to manage the tools more flexibly;
- It expanded the team dealing with provider assessments;
- It updated its reassessment questionnaire;
- It introduced a new standardized list of security measures that all providers must adhere to;
- It refined its risk assessment process to allocate resources more efficiently to the departments; and
- It ensures continuous awareness among providers regarding the program, including training executives and involving top management; and by broadly disseminating the email address to the Business Owners so that they can easily contact the team for assistance or if they have issues with providers.

23. From all these elements, it follows that (i) the defendant quickly took the necessary measures after the occurrence of the data breach; (ii) the inspection service found no determinations indicating that the defendant committed a violation; (iii) the defendant has thoroughly demonstrated that comprehensive measures were taken and that these measures are subject to continuous updating to prevent such incidents in the future. This leads the dispute chamber to conclude that the defendant did not violate the GDPR.

Decision in Case 170/2023 — 6/9

Decision in Case 170/2023 — 8/9

III. Publication of the Decision

24. In light of the importance of transparency regarding the decision-making process of the dispute resolution chamber, this decision will be published on the website of the Data Protection Authority. In accordance with its policy on the publication of its decisions, the dispute resolution chamber publishes each of its decisions with the aim of administrative transparency. This transparency is necessary both due to its role as a data protection supervisory authority (Article 57.1. b) and d) in conjunction with Article 51 of the GDPR) and due to its status as an administrative authority that is subject to the principles of good administration. In this capacity, the present decision will be published.

25. For this purpose, however, it is not necessary for the identification data of the parties to be disclosed directly.

26. Furthermore, when deciding on the publication, it was also taken into account that seven complaints had been submitted by German citizens who wanted to know what security measures the defendant had taken to prevent data breaches. These complaints are directly related to the data breach that is the subject of this decision. These complainants not only have the right to a decision from the dispute resolution chamber, which must necessarily address the same considerations as in the present decision, but it cannot be ignored that the complainants, due to the nature of the facts underlying their complaint and which are directed against the defendant in the present decision, are aware of the identity of the defendant. However, the dispute resolution chamber is not authorized to prohibit these complainants from disclosing the decision made by the dispute resolution chamber or to prohibit its publication. Therefore, the dispute resolution chamber believes that it is not possible to grant the defendant's request to refrain from publication, as the publication of the present decision could potentially disrupt the defendant's daily operations due to a flood of inquiries from customers who have been unduly alarmed.

27. However, the dispute resolution chamber believes that the present decision, in contrast, shows that the defendant has done everything to process the personal data of customers in accordance with the GDPR, particularly with regard to data security, and serves as an example for its industry concerning data protection as well as the attention and continuous measures taken to constantly adapt to developments in this area.

In accordance with Article 108, paragraph 1 of the LCA, an appeal against this decision may be lodged with the Market Court (Court of Appeal Brussels) within 30 days of its notification, with the Data Protection Authority (DPA) acting as the defendant.

Such a legal remedy can be submitted by means of an interim application, which must contain the information listed in Article 1034ter of the Code of Civil Procedure. The interim application must be submitted in accordance with Article 1034quinquies of the Belgian Code of Civil Procedure to the registry of the Market Court or via the e-Deposit information system of the Ministry of Justice (Article 32ter of the Belgian Code of Civil Procedure).

(get). Hielke HIJMANS

Chairman of the Dispute Resolution Chamber

2 The application must include, under penalty of nullity, the following information:

1° the indication of day, month, and year;

2° name, first name, address of the applicant, as well as, if applicable, their capacity and their national register number or company number;

3° name, first name, address, and, if applicable, the capacity of the person to be summoned;

4° the subject and a brief statement of the reasons for the application;

5° the indication of the judge dealing with the application;

6° the signature of the applicant or their lawyer.

3 The application and its annex are to be sent in as many copies as there are parties involved by registered mail to the court clerk of the court or deposited at the registry.

FOR THESE REASONS,

the dispute resolution chamber of the Data Protection Authority decides, after deliberation, to dismiss the present complaint in accordance with Article 100, paragraph 1, item 1 of the LCA, as no violation of the GDPR can be established in this regard.